BERICHT ZUM CYBERSICHERHEITSVORFALL (INCIDENT REPORT)

Thema: Analyse einer Rhadamanthys Infostealer Malware-Infektion und Datendiebstahl
Datum: Februar 2026 **Analyst:** Viktor Vas **Status:** Geschlossen / Wiederhergestellt

1. EXECUTIVE SUMMARY (Management-Zusammenfassung)

Dieser Bericht dokumentiert einen gezielten Malware-Angriff auf eine persönliche Workstation und die damit verbundene digitale Identität. Der Angriff begann mit einer kompromittierten Lieferkette ("Supply Chain"-ähnliche Infektion). Durch Social Engineering und fehlerhafte Sicherheitskonfigurationen, die von einer Künstlichen Intelligenz (ChatGPT) empfohlen wurden, konnte der Endgeräteschutz (EDR/Windows Defender) umgangen werden. Im Rahmen der Untersuchung wurden die Angreifer-Infrastruktur (C2-Server) und der Malware-Typ (**Rhadamanthys Stealer**) durch OSINT-Methoden erfolgreich identifiziert.

2. ANALYSE DER ANGRIFFSKETTE (Cyber Kill Chain)

2.1. Initialer Zugriff (Initial Access)

- **Vektor:** Malvertising / Drive-by-Download.
- **Ereignis:** Bei der Behebung von Treiberproblemen (Creative Sound Blaster) lud der Benutzer Drittanbietersoftware ("Driver Easy" und einen infizierten "SignalRGB"-Installer) herunter.
- **Sicherheitslücke:** Der Benutzer deaktivierte – basierend auf fehlerhaften Anweisungen eines LLMs (ChatGPT) – *Secure Boot*, die Kernisolierung (*Core Isolation/Memory Integrity*) und die Treibersignaturerzwingung (*Driver Signature Enforcement*).

2.2. Ausführung und Persistenz (Execution & Persistence)

- **Installation:** Die Schadsoftware wurde mit Administratorrechten installiert.
- **Process Injection:** Laut Malwarebytes-Protokollen injizierte sich die Malware in den legitimen Windows-Prozess `wmprph.exe` (Windows Media Player Rich Preview Handler).
- **Systemänderung:** Die kritische Datei `LsaIso.exe` (Credential Guard) wurde modifiziert (31.10.2025, 23:41 Uhr), was die Extraktion von Passwort-Hashes und Verschlüsselungscodes ermöglichte.

2.3. Command and Control (C2)

- **Kommunikation:** Der infizierte Host versuchte in regelmäßigen Abständen (*Beaconing*), eine Verbindung zum Server des Bedrohungsakteurs herzustellen.
- **Netzwerk-Indikator (IoC):**
  - **IP-Adresse:** `178.22.24.253`
  - **Port:** 58888
  - **Protokoll:** TCP / Outbound

2.4. Auswirkungen und Datendiebstahl (Actions on Objectives / Impact)

- **Session Hijacking:** Sitzungs-Cookies (*Session Cookies*) wurden aus den Browsern (Chrome) extrahiert.
- **Kontokompromittierung (Account Takeover):**
  - **Ubisoft:** Unbefugter Login aus Sierra Leone (`197.***.***.65`).
  - **Microsoft:** Dauerhafte Sperrung und Löschung des Kontos aufgrund von Manipulationen der Sicherheitsdaten ("irreversibly suspended").
  - **Instagram:** Verbreitung von Kryptowährungs-Betrug ("Elon Musk Doubling Scam") im Namen des Profils (*Lateral Movement*).
  - **Crypto Mining:** Heimliche Nutzung der Hardware-Ressourcen für Krypto-Mining (hohe Systemauslastung im Leerlauf).

3. THREAT INTELLIGENCE & OSINT

Eigene Open-Source-Intelligence-Recherchen (OSINT) zur Angreifer-Infrastruktur ergaben folgende Erkenntnisse:

- **IP-Attribution:** Die IP-Adresse `178.22.24.253` gehört zum Netzwerk von **Galeon LLC / CyberTech**.
- **Geografischer Standort:** Moskau, Russische Föderation.
- **Malware-Identifikation:** Basierend auf der Community-Datenbank von VirusTotal und der Verhaltensanalyse (*Behavioral Analysis*) gehört die Schadsoftware zur **Rhadamanthys Stealer**-Familie.
- **Modus Operandi:** Dieser Infostealer zielt spezifisch auf Gamer ab und nutzt infizierte "Cheat"-, "Mod"- oder "Treiber"-Pakete (z. B. `aimbot-for-cs2.zip`), um Passwörter und Krypto-Wallets zu stehlen.

4. BEHEBUNG UND WIEDERHERSTELLUNG (Remediation & Recovery)

Nach der Erkennung des Angriffs wurde das folgende "Scorched Earth"-Protokoll (vollständige Neuaufsetzung) durchgeführt:

1. **Isolation:** Sofortige Trennung der infizierten Workstation vom Netzwerk (Containment).

2. **Bereinigung:** Vollständige Formatierung des Systemlaufwerks und saubere Neuinstallation (*Clean Install*) des Betriebssystems.
3. **Netzwerk-Sanierung:** Zurücksetzen der Router auf die Werkseinstellungen (*Factory Reset*), um mögliche DNS-Hijacking-Risiken zu beseitigen.
4. **Identitätsschutz:** Änderung der Passwörter aller betroffenen Konten (strenge Passwortrichtlinie + Offline-Backup) und Beendigung aller aktiven Sitzungen (*Session Revocation*).
5. **Hardware-Austausch:** Austausch von Mobiltelefon und SIM-Karte zur Minimierung von "Smishing"- (SMS-Phishing) und Synchronisationsrisiken.

5. ERKENNTNISSE UND ZUKÜNFTIGER SCHUTZ (Lessons Learned)

- **KI-Risiko:** Die unkritische Übernahme von sicherheitsmindernden Empfehlungen einer Künstlichen Intelligenz (ChatGPT) stellt ein kritisches Risiko dar ("Alignment Problem").
- **Defense in Depth:** Ein mehrschichtiger Sicherheitsansatz (DNS-Filterung, EDR, 2FA) ist unerlässlich.
- **Neue Sicherheitsprotokolle:**
    - Ausführung und Tests von verdächtiger Software ausschließlich in isolierten Umgebungen (**Windows Sandbox**).
    - Verwendung eines dedizierten Passwort-Managers anstelle der browserbasierten Passwortspeicherung.
    - Implementierung des "Zero Trust"-Prinzips für alle heruntergeladenen Dateien (obligatorische Überprüfung via VirusTotal).

---

6. ANHÄNGE (Beweismaterial / Evidence)

Abbildung 1: *Malwarebytes-Protokoll des C2-Traffics. Beweis für Process Injection in die* `wmprph.exe` *und ausgehende Verbindung zur IP* `178.22.24.253`*.*

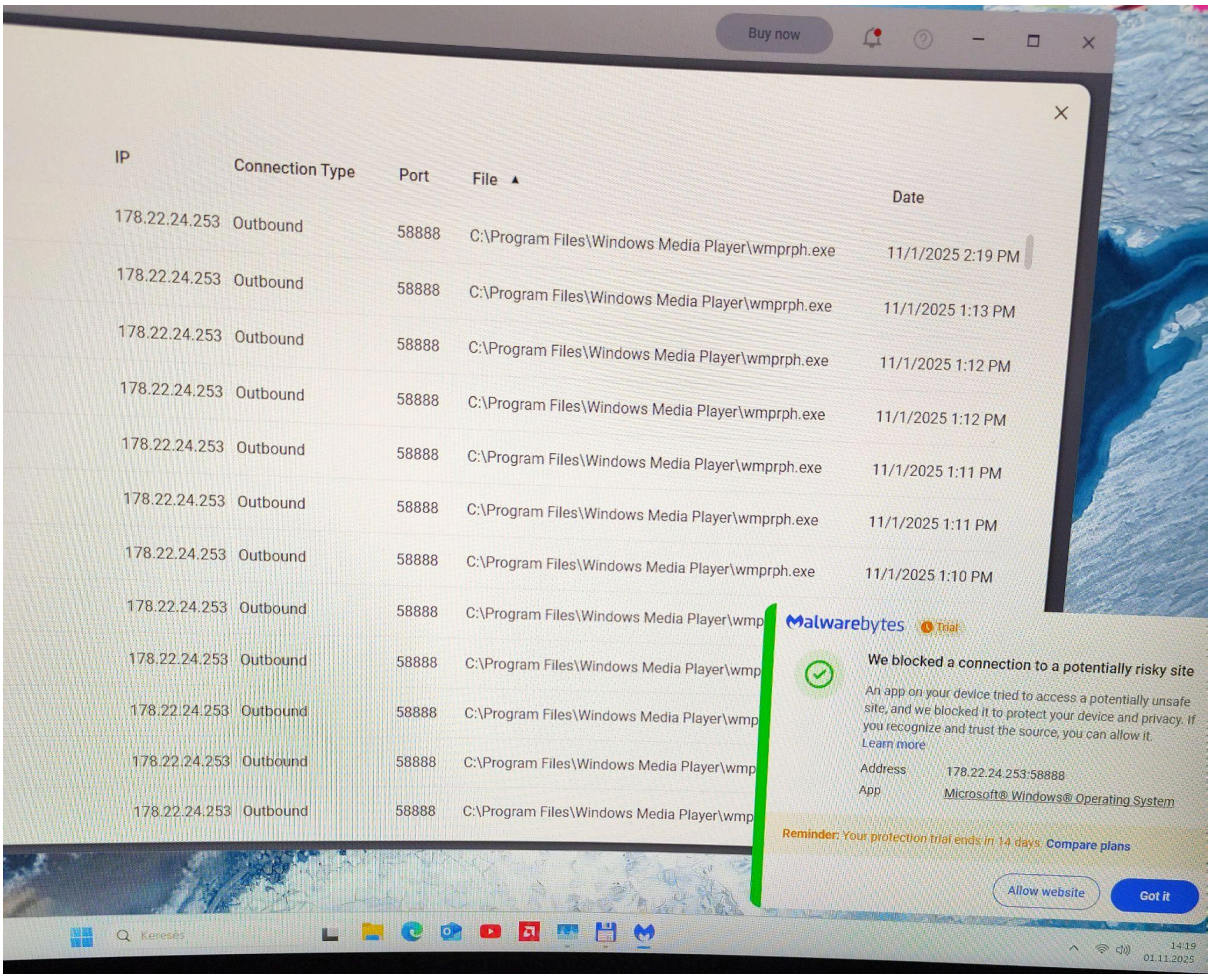
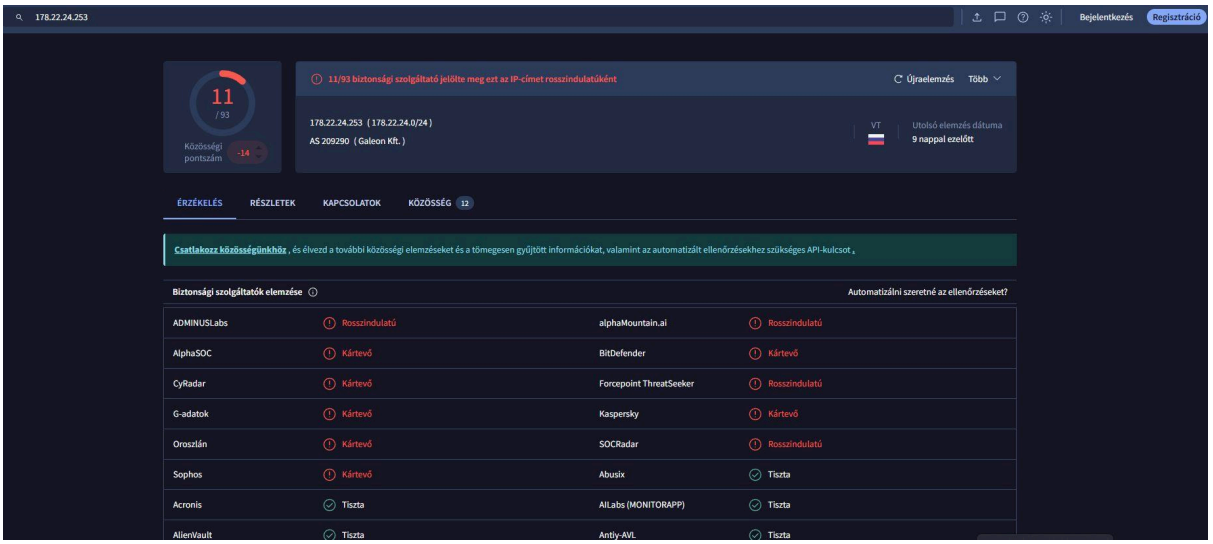


Abbildung 2: *VirusTotal OSINT-Analyse. Identifikation der IP-Adresse, Zuordnung zu Galeon LLC und der Rhadamanthys-Malware.*



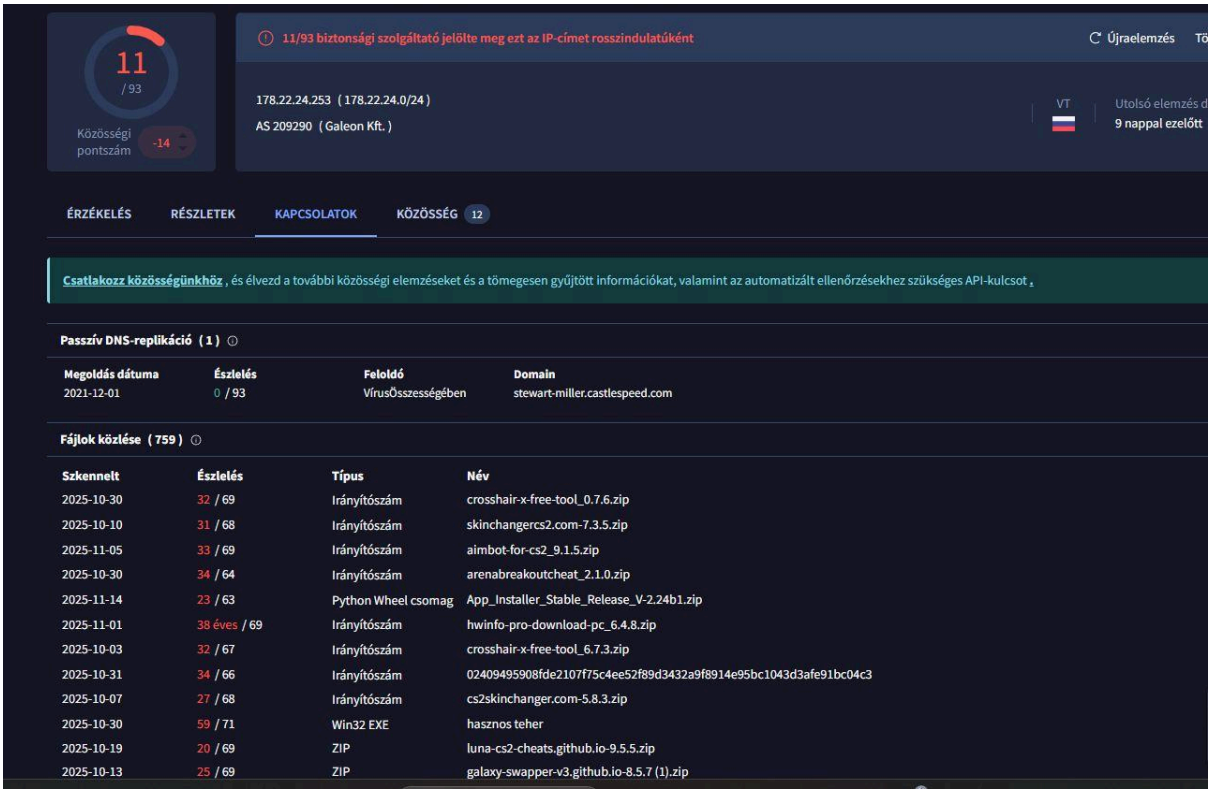


Abbildung 3: *Shodan-Scan der Angreifer-Infrastruktur. Nachweis offener Ports auf dem Moskauer Server.*

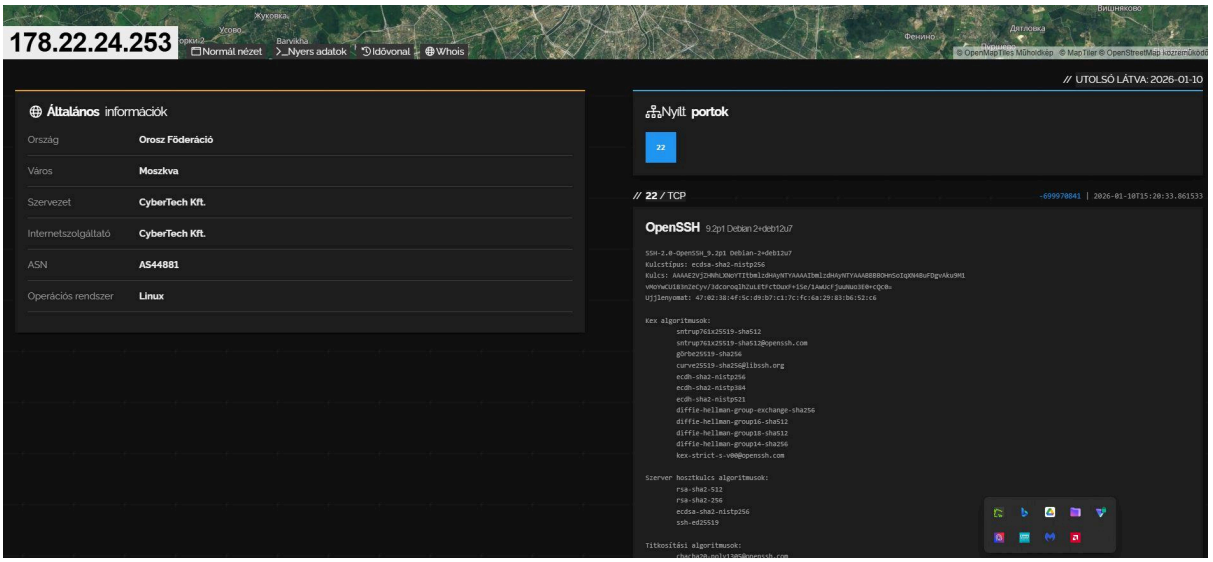


Abbildung 4: *Nachweis des Impacts (Auswirkungen). Unbefugter Login-Versuch bei Ubisoft aus Sierra Leone.*

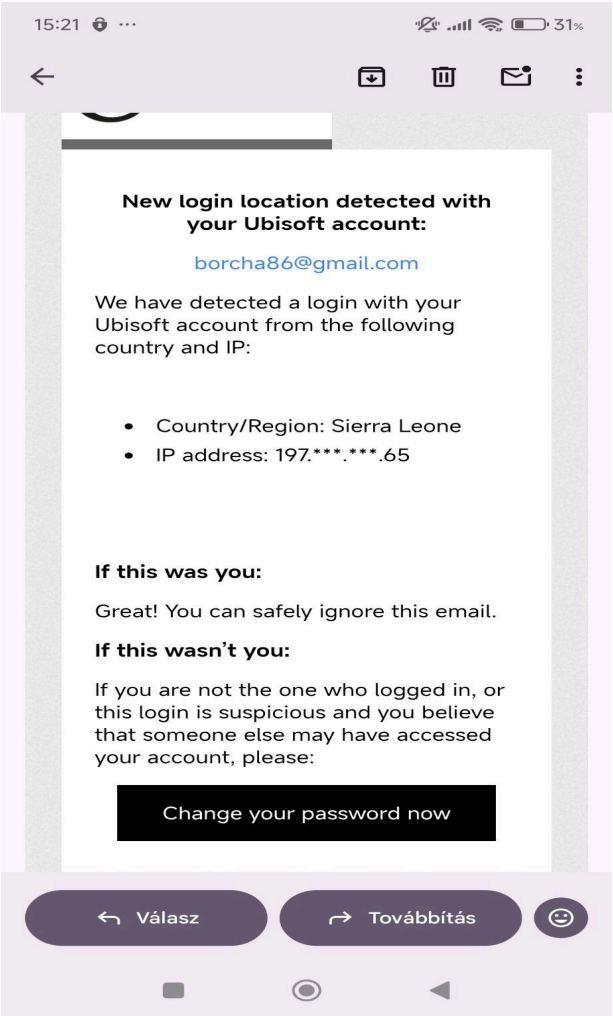
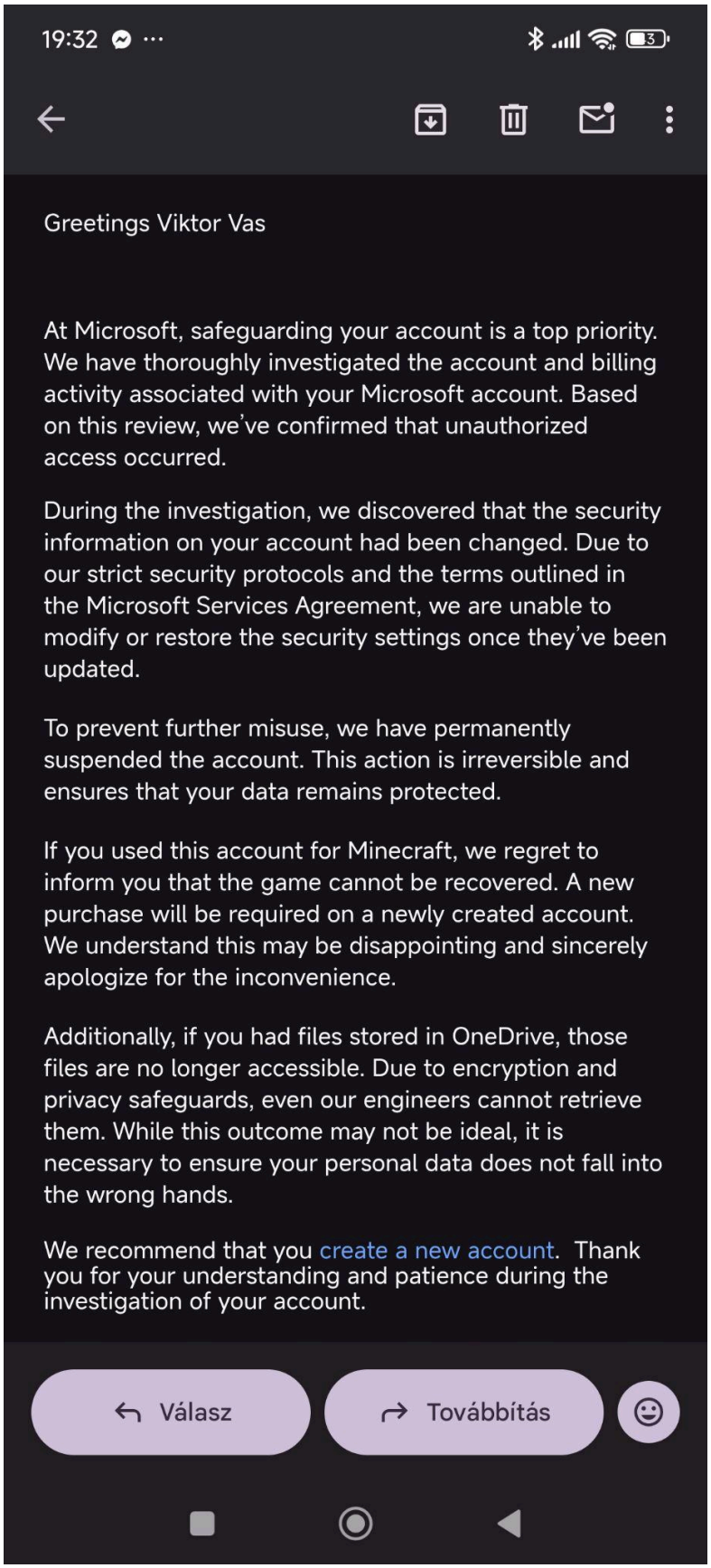


Abbildung 5: *Dauerhafte Sperrung des Microsoft-Kontos*



19:32

Greetings Viktor Vas

At Microsoft, safeguarding your account is a top priority. We have thoroughly investigated the account and billing activity associated with your Microsoft account. Based on this review, we've confirmed that unauthorized access occurred.

During the investigation, we discovered that the security information on your account had been changed. Due to our strict security protocols and the terms outlined in the Microsoft Services Agreement, we are unable to modify or restore the security settings once they've been updated.

To prevent further misuse, we have permanently suspended the account. This action is irreversible and ensures that your data remains protected.

If you used this account for Minecraft, we regret to inform you that the game cannot be recovered. A new purchase will be required on a newly created account. We understand this may be disappointing and sincerely apologize for the inconvenience.

Additionally, if you had files stored in OneDrive, those files are no longer accessible. Due to encryption and privacy safeguards, even our engineers cannot retrieve them. While this outcome may not be ideal, it is necessary to ensure your personal data does not fall into the wrong hands.

We recommend that you create a new account. Thank you for your understanding and patience during the investigation of your account.

Válasz

Továbbítás